

📍 Avenue V. Maistriau 8a
B-7000 Mons

☎ +32 (0)65 33 81 54

📧 scitech-mons@heh.be

WWW.HEH.BE

Projet Cyber Sécurité 2024-2025

- Rapport : Disaster Recovery Plan (DRP)

Bachelier en Télécommunication et développement
Orientation Sécurité

Table des matières

Robin Gillard & Charles Noël

robin.gillard1@std.heh.be

charles.noel@std.heh.be

Plan de Reprise d'Activité (DRP) pour l'Infrastructure Réseau et Sécurité	4
Résumé exécutif	4
Introduction	4
Objectif du DRP	4
Portée du document	4
Équipe responsable	4
Analyse des risques et des impacts	5
Identification des risques potentiels	5
Évaluation de l'impact business	5
Stratégie de sauvegarde et récupération	6
Politique de sauvegarde	6
Architecture de récupération	6
Procédures de reprise détaillées	6
Récupération des UTM FortiGate	6
Restauration d'une configuration FortiGate	6
Rétablissement des règles de pare-feu	7
Restauration de la configuration NAT	8
Remise en service du routage	8
Rétablissement des tunnels VPN IPsec	9
Reconfiguration des services d'inspection et filtrage	9
Plan de test et maintenance	10
Tests périodiques	10
Maintenance du DRP	10
Programme de gestion des vulnérabilités	10
Conclusion	11
Annexes	11
A. Inventaire des équipements critiques	12
B. Schémas topologiques détaillés	12
C. Plan d'adressage et de nommage	12
D. Liste des contacts d'urgence	12
Procédure détaillée de dépannage – Annexe DRP	12
1. Préparation et collecte d'informations	13
2. Diagnostic initial	13
3. Vérification des configurations critiques	14
4. Tests ciblés et outils de diagnostic avancés	14
5. Résolution et remédiation	15
6. Communication et documentation	16
Check-list rapide de dépannage	16
Références Normatives	17
Guides Sectoriels	18

Informations du document

1.1 Contact

Nom	Gillard/Noël
Prénom	Robin/Charles
Groupe	Sécurité 2
Courriel	robin.gillard1@std.heh.be charles.noel@std.heh.be

1.2 Confidentialité

Les informations contenues dans ce document sont réservées à un usage interne à la HEH.

1.3 Termes et conditions

La personne de contact, étant l'auteur de ce rapport, est seule responsable des informations décrites comme étant fiables dans celui-ci. Toute modification du document original pour le projet, ne sera pas prise en compte et toute responsabilité du changement revient au rédacteur de ce document.

1.4 Changements

1	17/05/2025	Robin Gillard	Création du modèle de base
1.1	18/05/2025	Charles Noël	Ajout d'information au document
1.2	19/05/2025	Robin Gillard	Peaufinage des informations
1.3	21/05/2025	Robin Gillard	- Ajout des contacts d'urgence et de la procédure de Dépannage - Vérification du respect de normes

Contexte

Dans le cadre du projet de Cybersécurité de la HEH 2024-2025, il est primordial que toutes les équipes concernées soient au courant du plan de recouvrement d'urgence. Ce document stratégique intègre une analyse des risques matériels, logiciels et humains, ainsi que des procédures détaillées de restauration des équipements FortiGate, règles de pare-feu, tunnels VPN et services NAT.

Dans le cadre du projet, un Plan de recouvrement en cas de sinistre (DRP) a été mis en place. Il s'appuie sur des objectifs RTO/RPO hiérarchisés, des tests trimestriels de résilience et une gouvernance partagée entre étudiants, professeurs et responsables techniques. Le DRP intègre également des annexes opérationnelles (inventaire des équipements, schémas topologiques, contacts d'urgence) pour une mise en œuvre rapide lors d'incidents critiques.

Plan de Reprise d'Activité (DRP) pour l'Infrastructure Réseau et Sécurité

Résumé exécutif

Ce document présente le Plan de Reprise d'Activité (DRP) pour l'infrastructure réseau et sécurité de notre projet informatique à la Haute École en Hainaut. Il définit les procédures détaillées, les responsabilités et les stratégies nécessaires pour rétablir rapidement les services informatiques critiques en cas de sinistre ou d'incident majeur. Ce plan s'appuie sur les meilleures pratiques de l'industrie et sur une architecture réseau sécurisée utilisant des équipements FortiGate déployés dans une configuration à haute disponibilité.

Introduction

Objectif du DRP

Le présent Plan de Reprise d'Activité (DRP) a pour objectif de fournir un cadre méthodologique permettant de rétablir les opérations informatiques critiques suite à un incident ou une catastrophe affectant notre infrastructure réseau. Il détaille les procédures à suivre pour minimiser les temps d'arrêt et garantir la continuité des services essentiels.

Portée du document

Ce document couvre les aspects suivants de notre infrastructure :

- Configuration et récupération des UTM FortiGate
- Rétablissement des règles de pare-feu
- Restauration des configurations NAT
- Remise en service des tables de routage
- Rétablissement des tunnels VPN IPsec
- Reconfiguration des services d'inspection et de filtrage

Équipe responsable

Réalisateurs du DRP : Robin Gillard et Charles Noël

Analyse des risques et des impacts

Identification des risques potentiels

Plusieurs types de sinistres peuvent affecter notre infrastructure réseau :

1. **Défaillance matérielle** : Panne d'un équipement FortiGate, d'un commutateur ou d'un routeur
2. **Compromission de sécurité** : Attaque informatique, ransomware, ou violation de données
3. **Erreur humaine** : Mauvaise configuration, suppression accidentelle de règles
4. **Catastrophe naturelle** : Inondation, incendie, ou autre événement affectant les locaux 2/13 et 2/16
5. **Panne d'alimentation** : Coupure électrique prolongée
6. **Perte de connectivité WAN** : Défaillance des liaisons entre sites

Évaluation de l'impact business

Service	Criticité	RTO (Recovery Time Objective)	RPO (Recovery Point Objective)
Règles pare-feu	Critique	1 heure	24 heures
Configurations VPN	Haute	2 heures	24 heures
Services NAT	Haute	2 heures	24 heures
Routage	Critique	1 heure	24 heures
Services d'inspection (SSL/SSH, filtrage Web, antivirus)	Moyenne	4 heures	24 heures

Stratégie de sauvegarde et récupération

Politique de sauvegarde

1. Sauvegarde des configurations FortiGate

- Fréquence : Quotidienne automatique et avant chaque modification majeure
- Type : Configuration complète (chiffrée et non chiffrée)
- Stockage : Utilitaire de sauvegarde dédié (Local) style disque dur, usb, etc.. et un support en externe

2. Documentation des changements

- Journal de bord des modifications
- Sauvegarde des schémas topologiques
- Archivage du plan d'adressage et de nommage

Architecture de récupération

Notre architecture s'appuie sur le déploiement de deux sites principaux (centraux) avec une architecture hiérarchique et plusieurs LAN plus petits correspondant à des agences distantes. Chaque site dispose d'une zone DMZ sécurisée.

Procédures de reprise détaillées

Récupération des UTM FortiGate

Restauration d'une configuration FortiGate

1. Accès à l'interface d'administration

- Connectez-vous à l'interface CLI via la console ou SSH
- Alternativement, utilisez l'interface GUI via HTTPS

2. Restauration du firmware

- Vérifiez la version du firmware compatible avec la sauvegarde
- Téléchargez la version appropriée depuis le portail support Fortinet
- Suivez les étapes de mise à jour détaillées dans la section "Mise à jour du firmware"

3. Restauration de la configuration

- Via l'interface GUI :

System > Backup & Restore > Restore

- Via CLI :

```
execute restore config <filename>
```

4. Vérification post-restauration

- Vérifiez l'état des interfaces réseau
- Confirmez la table de routage
- Testez la connectivité de base

Rétablissement des règles de pare-feu

1. Vérification des règles restaurées

- Comparez avec la documentation du plan de pare-feu
- Assurez-vous que les objets d'adresse et de service sont correctement définis

2. Test des règles critiques

- Vérifiez la correspondance des règles avec le "Policy Lookup"
- Testez l'accès aux services essentiels
- Vérifiez les journaux pour confirmer le fonctionnement correct

Restauration de la configuration NAT

1. Vérification des objets VIP (Virtual IP)

- Confirmez que les adresses externes et mappées sont correctes
- Vérifiez que l'ARP reply est activé pour les VIP

2. Vérification des pools IP

- Confirmez les plages d'adresses pour la SNAT
- Vérifiez le type de pool (Overload, One-to-one, etc.)

3. Test de la NAT

- Testez la connectivité sortante pour vérifier la SNAT
- Testez l'accès aux services internes depuis l'extérieur pour vérifier la DNAT

Remise en service du routage

1. Vérification des routes statiques

- Confirmez que la table de routage contient toutes les routes nécessaires
- Vérifiez les priorités et les distances administratives

2. Configuration de l'ECMP si nécessaire

- Restaurez les paramètres de balancement de charge
- Vérifiez la distribution du trafic sur les interfaces multiples

3. Activation du RPF check

- Confirmez la configuration du Reverse Path Forwarding
- Vérifiez qu'il n'y a pas de blocage de trafic légitime

Rétablissement des tunnels VPN IPsec

1. Vérification des paramètres VPN

- Confirmez les paramètres de phase 1 et phase 2
- Vérifiez les clés pré-partagées ou les certificats

2. Test de la connectivité VPN

- Établissez les tunnels avec les sites distants
- Vérifiez l'état des SA (Security Associations)
- Testez la communication à travers le tunnel

3. Vérification des règles de pare-feu pour le VPN

- Assurez-vous que les règles permettent le trafic à travers les tunnels
- Vérifiez les routes pour le trafic VPN

Reconfiguration des services d'inspection et filtrage

1. Inspection SSL/SSH

- Restaurez les profils d'inspection
- Vérifiez les exemptions pour les services critiques

2. Filtrage Web

- Confirmez les politiques de filtrage par catégorie
- Vérifiez les listes blanches/noires

3. Antivirus

- Vérifiez la mise à jour des signatures
- Confirmez l'application des profils aux règles de pare-feu



Plan de test et maintenance

Tests périodiques

1. Tests trimestriels de restauration

- Restauration complète sur un équipement de test
- Validation de la procédure de restauration

2. Exercices de simulation

- Scénarios de panne pour valider les procédures
- Formation des équipes techniques

Maintenance du DRP

1. Mise à jour du document

- Après chaque changement significatif de l'infrastructure
- Revue annuelle complète

2. Responsabilités

- Mise à jour de l'inventaire : Responsable(s) inventaire
- Validation des procédures : Corp étudiant et Professoral
- Approbation des modifications : Corp étudiant et Professoral

Programme de gestion des vulnérabilités

Dans le cadre de notre stratégie de reprise, nous intégrons un programme de gestion des vulnérabilités visant à réduire les risques d'incidents :

1. Identification et surveillance

- Inventaire régulier des équipements physiques et logiciels
- Cartographie des flux de données

2. Priorisation des vulnérabilités

- Évaluation de la valeur de l'actif
- Évaluation de l'exposition aux menaces
- Évaluation de la difficulté de remédiation

3. Résolution des vulnérabilités

- Stratégies d'acceptation, d'atténuation ou de correction
- Application des correctifs après tests

4. Réévaluation continue

- Vérification des résolutions
- Documentation des actions
- Amélioration du processus

Conclusion

Ce Plan de Reprise d'Activité fournit un cadre systématique pour répondre efficacement aux incidents et garantir la continuité des services réseau essentiels. Sa mise en œuvre rigoureuse et sa mise à jour régulière sont essentielles pour maintenir la résilience de notre infrastructure face aux menaces et perturbations potentielles.

Le succès de ce plan repose sur l'engagement de tous les acteurs impliqués dans sa mise en œuvre et dans le respect des procédures établies. La documentation complète, les sauvegardes régulières et les tests périodiques sont les piliers qui garantiront notre capacité à répondre efficacement en cas de sinistre.

Annexes

A. Inventaire des équipements critiques

<https://hehbe.sharepoint.com/:x:/s/TemplateProjetcybercopier/EYDMtBjFOLVFkcrSUB3oX08Bk0X52kbly3O90H78IAKCzA?e=0hnZyb>

B. Schémas topologiques détaillés

[Schéma topologique typique d'une agence](#)

C. Plan d'adressage et de nommage

[Plan de nommage](#)

[Plan de nommage VDOM](#)

[Plan d'adressage](#)

D. Liste des contacts d'urgence

Denis Mandoux	denis.mandoux@heh.be	Responsable de projet
Yoan Pietrzak	yoan.pietrzak@heh.be	Responsable Réseau
Robin Gillard	robin.gillard1@std.heh.be	Responsable DRP
Charles Noël	charles.noel@std.heh.be	Co-Responsable DRP

Procédure détaillée de dépannage – Annexe DRP

Procédure détaillée de dépannage adaptée à l'infrastructure réseau sécurisée par FortiGate. Cette procédure couvre les étapes essentielles, du diagnostic à la résolution, pour les incidents courants sur les équipements réseau et de sécurité.

1. Préparation et collecte d'informations

- **Vérifier l'inventaire matériel et logiciel**
Consultez l'inventaire à jour pour identifier les équipements concernés (modèle, version de firmware, adresses IP, etc.).
- **Rassembler la documentation**
Récupérez les schémas topologiques, plans d'adressage, configurations sauvegardées et journaux de bord récents.
- **Identifier le responsable**
Désignez un responsable pour la gestion de l'incident et la communication avec les parties prenantes.

2. Diagnostic initial

- **Vérifier l'état physique**
 - Contrôlez l'alimentation, les voyants, les connexions câblées et l'environnement matériel (température, ventilation).
 - Si le matériel est inaccessible, tentez un accès console (RJ45-série, USB, etc.).
- **Tester la connectivité réseau**
 - Utilisez des outils de base (ping, traceroute) pour vérifier l'accessibilité des équipements et des réseaux critiques.
 - Vérifiez les interfaces réseau sur le FortiGate (GUI/CLI : `get system interface`).

- **Analyser les logs**

- Consultez les journaux d'événements et de trafic (GUI : Log & Report > Log Settings ; CLI : `execute log display`).
- Identifiez les erreurs, alertes ou comportements anormaux (chutes d'interface, déconnexions VPN, etc.).



3. Vérification des configurations critiques

- **Pare-feu et NAT**

- Vérifiez l'état et l'ordre des règles de pare-feu (GUI : Policy & Objects > Firewall Policy ; CLI : `show firewall policy`).
- Contrôlez la configuration NAT (VIP, IP Pool) et les correspondances avec les règles de pare-feu.

- **Routage**

- Affichez la table de routage active (CLI : `get router info routing-table all`).
- Vérifiez la présence de routes statiques/dynamiques nécessaires et leur priorité.

- **VPN**

- Vérifiez l'état des tunnels IPsec (GUI : VPN > Monitor ; CLI : `diagnose vpn tunnel list`).
- Contrôlez les paramètres de phase 1/2, les routes associées et les règles de pare-feu pour le trafic VPN.

- **Services d'inspection**

- Vérifiez l'application des profils de sécurité (antivirus, filtrage web, inspection SSL/SSH) sur les règles concernées.

4. Tests ciblés et outils de diagnostic avancés

- **Capture de paquets**
 - Utilisez l'outil de capture intégré (CLI : `diagnose sniffer packet <interface> <filter> <level> <count> <timestamp> <frame size>`) pour analyser le trafic problématique.
 - **Policy Lookup**
 - Vérifiez quelle règle s'applique à un flux donné (GUI : Policy & Objects > Policy Lookup)¹.
 - **Reverse Path Forwarding (RPF)**
 - Vérifiez la configuration RPF si du trafic légitime est bloqué (CLI : `config system interface ... set src-check ...`).
-

5. Résolution et remédiation

- **Redémarrage contrôlé**
 - Si nécessaire, redémarrez l'équipement de façon contrôlée après sauvegarde de la configuration.
 - Si l'accès administrateur est perdu, utilisez la procédure de récupération de mot de passe (console, login `maintainer`, mot de passe `bcpb<N°-de-série>` dans la minute suivant le boot).
- **Restauration de configuration**
 - Si la configuration est corrompue ou perdue, restaurez la dernière sauvegarde valide (GUI : System > Backup & Restore ; CLI : `execute restore config <filename>`).
- **Mise à jour du firmware**
 - Vérifiez la version du firmware et appliquez les mises à jour nécessaires, en suivant l'upgrade path recommandé et après sauvegarde complète.
- **Correction des règles/configurations**

- Modifiez ou réappliquez les règles de pare-feu, NAT, routage, VPN ou profils de sécurité selon les besoins identifiés lors du diagnostic.

- **Validation**

- Testez la résolution du problème par des vérifications fonctionnelles (connectivité, accès aux services, logs)¹.
- Documentez toutes les actions menées et les résultats obtenus.

6. Communication et documentation

- **Informez les parties prenantes**

- Communiquez l'état d'avancement et la résolution à l'équipe, aux utilisateurs impactés et à la direction si nécessaire.

- **Mise à jour du journal de bord**

- Notez l'incident, la cause, les actions correctives et les recommandations pour éviter la récurrence.

- **Analyse post-incident**

- Organisez un retour d'expérience pour améliorer la procédure de dépannage et le DRP.

Check-list rapide de dépannage

- ☐ Contacter un des responsables cité dans l'annexe D pour le mettre au courant de la situation
- ☐ Vérifier l'alimentation et la connectique
- ☐ Tester l'accessibilité réseau (ping, SSH, GUI)
- ☐ Analyser les logs et alertes
- ☐ Vérifier les règles de pare-feu/NAT
- ☐ Contrôler la table de routage et les tunnels VPN
- ☐ Utiliser la capture de paquets si besoin
- ☐ Restaurer la configuration ou le firmware si nécessaire
- ☐ Documenter l'incident et la résolution

Références Normatives

1. ISO 22301:2019

- *Sécurité et résilience — Systèmes de management de la continuité d'activité — Exigences.*
- Lien : <https://www.iso.org/obp/ui/fr/>

2. NIST SP 800-34 Rev. 1

- *Contingency Planning Guide for Federal Information Systems.*
- Lien : <https://www.schellman.com/blog/federal-compliance/overview-nist-800-series-special-publications>

Guides Sectoriels

3. Appvizer

- *Guide pratique et modèle de DRP.*
- Lien : <https://www.appvizer.fr/magazine/services-informatiques/pca/plan-de-reprise-activite>

4. Zscaler

- *Étapes clés pour un DRP efficace.*
- Lien : <https://www.zscaler.com/fr/zpedia/what-is-a-disaster-recovery-plan>

5. SafetyCulture

- *Guide étape par étape pour l'évaluation des risques et les tests.*
- Lien : <https://safetyculture.com/fr/themes/plan-de-reprise-dactivite-apres-sinistre/>

6. Secureframe

- *Checklist pour l'analyse d'impact et la maintenance.*
- Lien : <https://secureframe.com/fr-fr/blog/disaster-recovery-plan>

7. BL Digital

- *Conseils sur les éléments obligatoires d'un DRP.*
- Lien :
<https://bldigital.it/fr/comment-creeer-un-plan-de-reprise-dactivite-apres-sinistre-efficace-disaster-recovery-plan/>

8. Win

- *Recommandations sur les tests et la gouvernance.*
 - Lien :
<https://www.win.be/fr/blog-news/pourquoi-vous-ne-pouvez-pas-passer-a-cote-dun-plan-de-reprise-apres-sinistre-drp>
-